A Practical Framework for Detecting Common Web Application Security Risks

Student Research Proposal • Mahbub Alam Abid • Cybersecurity • Web Security • Machine Learning

Proposed by	Mahbub Alam Abid
Project type	Student-led research / prototype study
Estimated duration	8–10 weeks

Project Overview

This student-led project proposes a small, practical framework that can help identify common security weaknesses in web applications and present the findings in a way that is easy for developers and students to understand. The initial focus will be on SQL injection and cross-site scripting patterns, with room to explore simple machine-learning-assisted classification later.

Student perspective
The project is intentionally scoped so that a small student team can learn, experiment, and produce a useful research artifact without assuming access to a large laboratory or proprietary dataset.

Research Problem

Web application security concepts are often learned through isolated examples, while real applications contain many different inputs and validation points. For a student researcher, it is useful to connect the theory of common vulnerabilities with a repeatable testing and reporting process. The project therefore aims to build a controlled prototype that can inspect selected inputs and classify potentially risky patterns without attempting to attack real systems.

Research Objectives

- Design a small test environment containing intentionally vulnerable and securely implemented web endpoints.
- Study how input validation, parameterized queries, output encoding, and security headers reduce common risks.
- Develop a lightweight rule-based detection layer for suspicious input patterns.
- Explore whether basic machine learning can help classify previously unseen examples after a suitable dataset is prepared.
- Produce a clear report showing false positives, false negatives, limitations, and practical recommendations.

Research Questions

RQ1. What input characteristics are useful for identifying common attack patterns?

RQ2. How much can a simple rule-based detector achieve before ML is introduced?

RQ3. Which security controls make the largest practical difference?

RQ4. Where does automated detection become unreliable and require human review?

Proposed Methodology

Step 1. Create a local, isolated web application with safe demonstration cases for SQL injection and XSS.

Step 2. Collect labeled examples from the controlled environment and publicly available educational security datasets where licensing permits.

Step 3. Start with interpretable rules and regular expressions as a baseline.

Step 4. Compare the baseline with a simple supervised ML model if the dataset is large and clean enough.

Step 5. Evaluate precision, recall, and false-positive rate, then document where the approach should not be trusted.

Data / Materials / Experimental Resources

The exact resources will be finalized with the collaborator after a feasibility discussion. The preferred approach is to start with public or self-generated material, keep the experiment small enough to reproduce locally, and record the source, preprocessing decisions, assumptions, and version of each important component.

Initial resource plan: Controlled local web application, safe vulnerability examples, labeled input samples.

Evaluation Plan

Evaluation will be based on measurable criteria rather than only a successful demo. Depending on the project, this may include classification metrics, detection quality, latency, error analysis, reproducibility, or qualitative review. Baselines will be established before more complex techniques are introduced so that the contribution of each change can be discussed clearly.

Reproducibility and Documentation

The team will keep a simple experiment log containing dataset versions, preprocessing choices, model or system settings, evaluation results, and important observations. Code will be organized so that the main experiment can be rerun without relying on undocumented manual steps. Charts and tables will be generated from saved results where possible.

Expected Challenges

- Limited time and computing resources may require a smaller experimental scope.
- Dataset quality may affect conclusions more than model complexity.
- A strong-looking metric may hide weaknesses that appear during error analysis.
- The research question may need refinement after an initial feasibility experiment.

Planned Mitigation

The project will begin with a small baseline and a feasibility check. If data or hardware limitations make the original scope unrealistic, the team will narrow the research question rather than artificially inflating results. Each limitation will be reported as part of the final research discussion.

Expected Outcomes

- A working academic prototype for controlled vulnerability-pattern detection.
- An evaluation dataset and documented testing procedure.
- Comparison between rule-based and basic ML-assisted classification.
- A research-style report describing findings, limitations, and future improvements.

Potential Research Collaboration

I am especially interested in collaborating with someone who can help with security testing methodology, dataset preparation, or ML evaluation. A researcher with experience in web security would also help me make the experimental design more rigorous.

Technical Stack

Python, JavaScript, SQL, Node.js/Express, Git; optional scikit-learn for the ML component.

Scope, Ethics, and Responsible Research

An isolated academic environment will be used. No external system will be tested without explicit permission. The project will avoid storing unnecessary personal information and will document limitations rather than presenting the prototype as a production security scanner.

Proposed Work Plan

Phase	Activities
1. Background study	Literature review, problem definition, feasibility check
2. Setup	Dataset/system preparation and baseline implementation
3. Experiments	Development, comparison, tuning, and documentation
4. Evaluation	Metrics, error analysis, limitations, reproducibility
5. Reporting	Results, discussion, documentation, and presentation

What I Am Looking for in a Collaborator

I am looking for someone who is genuinely interested in the research question and willing to contribute to discussion, implementation, experiment design, data analysis, or writing. I would prefer to divide work according to each person's strengths and keep decisions, code, data, and results documented.

Possible Next Step

If a researcher is interested, I would like to first discuss the research question, available resources, and a realistic scope. After that discussion, the proposal can be refined into a clearer study plan with specific responsibilities and milestones.

Note: This document describes a proposed student project. It does not claim completed research, published results, or guaranteed performance. The scope is open to refinement through collaboration.